

# ISO安全机制与安全服务

表 1-1 安全服务与安全机制的关系

| 服务 \ 机制    | 加密<br>机制 | 数字<br>签名 | 访问<br>控制 | 数据<br>完整<br>性 | 认证<br>交换 | 流<br>量<br>填<br>充 | 路<br>由<br>控<br>制 | 公<br>证<br>机<br>制 |
|------------|----------|----------|----------|---------------|----------|------------------|------------------|------------------|
| 对等实体认证     | √        | √        |          |               | √        |                  |                  |                  |
| 数据源认证      | √        | √        |          |               |          |                  |                  |                  |
| 访问控制服务     |          |          | √        |               |          |                  |                  |                  |
| 连接机密性      | √        |          |          |               |          |                  | √                |                  |
| 无连接机密性     | √        |          |          |               |          |                  | √                |                  |
| 选择字段机密性    | √        |          |          |               |          |                  |                  |                  |
| 通信业务流机密性   | √        |          |          |               |          | √                | √                |                  |
| 带恢复的连接完整性  | √        |          |          | √             |          |                  |                  |                  |
| 不带恢复的连接完整性 | √        |          |          | √             |          |                  |                  |                  |
| 选择字段连接完整性  | √        |          |          | √             |          |                  |                  |                  |
| 无连接完整性     | √        | √        |          | √             |          |                  |                  |                  |
| 选择字段无连接完整性 | √        | √        |          | √             |          |                  |                  |                  |
| 不可抵赖，带交付证据 |          | √        |          | √             |          |                  |                  | √                |

5

通信业务流机密性服务需要使用的安全机制包括（ ）。

- ☐ A 访问控制
- ☒ B 加密
- ☐ C 流量填充
- ☐ D 路由控制

提交

60

互联网中大量存在的“中间盒子”不符合互联网设计之初提出的（ ）原则，导致了大量网络攻击事件的发生。

- ☒ A 端到端
- ☐ B 尽力而为
- ☐ C 分组交换
- ☐ D 分层设计

提交

## IPsec

- IPsec (IP Security)

- 端到端的确保 IP 通信安全：认证、加密及密钥管理
- 为IPv6制定（必选），支持IPv4（可选）
- IPv6通过IPsec来保证IP层的传输安全，提高了网络传输的保密性、完整性、可控性和抗否认性

## IPv6

- 从IPv4向IPv6过渡采用逐步演进的方法，IETF推荐的过渡方案主要有：

- 双协议栈(dual stack)
- 隧道(tunneling) IPv6数据包作为数据封装在IPv4数据包里，该包的源地址和目的地址分别是隧道的入口和出口的IPv4地址。
- 网络地址转换 维护IPv6与IPv4地址的映射表



## IPv6安全

- 安全问题

- IPv4向IPv6过渡技术的安全风险：协调攻击

- 无状态地址自动配置的安全风险：针对邻居发现协议NDP攻击

- ◆请同学们利用AI工具学习书中P75最后一段内容，并讲解

- IPv6中PKI (公钥基础设施) 管理系统的安全风险

- IPv6编址机制的隐患

- IPv6的安全机制对网络安全体系的挑战所带来的安全风险：

- 正在服役的IDS（入侵检测系统）/IPS（入侵防御系统）/WAF

- （Web应用防火墙）不一定支持，于是可以畅行无阻。

下列认证方式中，不属于 OSPF 协议定义的认证方法是（ ）。

- ☐ A NULL 认证
- ☐ B 简单口令认证
- ☐ C MD5 加密认证
- ☒ D SHA1 加密认证

提交

## WHOIS数据库主要用于查询什么信息？

- ☐ A 目标系统的开放端口
- ☒ B 域名注册者和IP分配信息
- ☐ C 社交媒体的用户资料
- ☐ D 漏洞的CVE编号

提交

拖库和撞库是两种不同的网络攻击手段，主要区别如下：

### 攻击目的

- 。 **拖库**：黑客的主要目的是入侵有价值的网络站点，窃取其注册用户的资料数据库，获取大量用户的敏感信息，如用户名、密码、邮箱、联系方式等。
- 。 **撞库**：是利用从其他途径获取的用户信息和密码，尝试批量登录其他网站，以获取用户在这些网站上的相关账号和敏感信息，比如在电商平台获取用户的购物记录、支付信息，或者在社交平台获取用户的好友列表、聊天记录等。

### 攻击方式

- 。 **拖库**：需要黑客具备较高的技术水平，利用网络和数据库系统的漏洞，通过攻击破解等技术手段，如利用 **Web Services** 漏洞、服务器漏洞，挂马、病毒、木马后门等，在网站服务器上建立后门，从而获取服务器操作系统的权限，进而窃取数据库文件。
- 。 **撞库**：相对来说技术含量较低，黑客收集在互联网上已经泄露的用户和密码信息，生成对应的字典表，然后使用自动化系统或脚本，批量尝试登录其他网站。

端口扫描的主要功能是（ ）。

- ☒ **A** 探测目标主机上开放了哪些网络服务
- ☐ **B** 探测主机是否开机
- ☐ **C** 识别操作系统的类型
- ☐ **D** 判断目标主机上是否存在某个已公开的漏洞

提交

与攻防技术

漏洞扫描能够识别的漏洞类型是（ ）

- ☒ **A** 已知漏洞
- ☐ **B** 未知漏洞
- ☐ **C** 已知漏洞和未知漏洞
- ☐ **D** 所有漏洞

提交

与攻防技术

### 1. 分布式攻击 (Distributed Attack)

- 定义：指利用多台计算机或设备协同发起的攻击，通过分散的攻击源对目标实施破坏。
- 范畴：是一个更广泛的概念，涵盖多种攻击类型，DDoS 是其中一种典型形式。

### 2. DDoS (分布式拒绝服务攻击)

- 定义：通过控制大量“肉鸡”（被黑客植入恶意程序的主机），同时向目标服务器发送海量无效请求，耗尽其资源（如带宽、内存、CPU），导致正常用户无法访问服务。
- 范畴：属于分布式攻击的子集，专注于“拒绝服务”这一特定攻击目标。

---

## 反射型DDoS：常用协议

- 用作反射型DDoS的协议一般具有哪些特点？
  - 互联网上有很多可探测到的支持该协议的服务器；
  - 协议的请求报文大小远小于响应报文的大小；
  - 协议具有无连接特性。

---

## 流量清洗

- DDoS攻击防御就是对DDoS攻击与正常业务数据混合在一起的流量进行净化，净化掉DDoS攻击流量，保留正常业务流量，保证客户业务7×24小时的不间断提供。
- DDoS攻击阻断过程一般包括攻击监测和判断、流量牵引、清洗过滤、流量回送四个关键环节。

以下哪一项是木马（Trojan Horse）的主要特征？

- ☐ A 能够自我复制并感染其他文件
- ☒ B 伪装成合法程序，诱骗用户执行
- ☐ C 通过U盘自动传播，无需用户交互
- ☐ D 仅影响操作系统内核，不窃取数据

● 病毒、蠕虫、木马的区别

| 比较项目     | 病毒        | 蠕虫            | 木马              |
|----------|-----------|---------------|-----------------|
| 存在形式     | 代码片段      | 独立个体          | 独立个体            |
| 复制机制     | 插入到宿主程序   | 自身的拷贝         | 自身的拷贝           |
| 传染机制     | 宿主的运行     | 系统存在的网络安全漏洞   | 主动或被动植入到目标计算机   |
| 攻击目标     | 本地文件      | 网络上的计算机       | 本地文件和系统、网络上的计算机 |
| 计算机使用者角色 | 病毒传播的关键环节 | 无关（通过程序自身）    | 木马传播的关键环节       |
| 防治措施     | 从宿主文件中清除  | 为系统打补丁（Patch） | 停止并删除木马服务程序     |

静态口令面临的安全威胁

- 口令监听
- 截取/重放
- 穷举攻击
- 口令猜测
- 字典攻击
- 伪造服务器攻击
- 口令泄露
- 直接破解口令文件

网络监听（Sniffing）通常发生在OSI模型的哪一层？

- ☐ A 物理层
- ☒ B 数据链路层
- ☐ C 网络层
- ☐ D 传输层

防御ARP欺骗监听的最佳方法是？

- ☐ A 使用HTTP协议
- ☒ B 配置静态ARP绑定
- ☐ C 关闭防火墙
- ☐ D 禁用交换机

提交

1. 缓冲区溢出攻击的核心原因是？

- ☐ A 操作系统漏洞
- ☒ B 程序对内存缓冲区的边界检查缺失
- ☐ C 网络协议缺陷
- ☐ D 硬件故障

## 堆的特点

- ◆堆的增长方向：从内存低端到内存高端（与栈相反）；
- ◆堆的分配和释放可以由用户自由控制；
- ◆堆的空间不一定连续；
- ◆堆申请函数返回指向堆内存的指针，后续对于内存的读写等操作需要通过此指针进行；
- ◆不同的系统有着不同的堆管理机制。



以下哪个函数最容易引发栈缓冲区溢出？

- ☐ A strncpy
- ☐ B fgets
- ☒ C gets
- ☐ D snprintf

在编程中，某些函数由于设计缺陷或缺乏边界检查，容易引发缓冲区溢出漏洞。以下是常见的高风险函数及其风险点，按语言分类整理：

字符串处理函数

| 函数      | 风险描述                                              | 安全替代方案           |
|---------|---------------------------------------------------|------------------|
| strcpy  | 无长度检查，直接复制字符串直到遇到 <code>\0</code> ，可能溢出目标缓冲区。     | strncpy、snprintf |
| strcat  | 追加字符串时不检查目标缓冲区剩余空间，易导致溢出。                         | strncat、snprintf |
| sprintf | 格式化字符串时不限制输出长度，可能写入超过缓冲区大小的数据。                    | snprintf         |
| gets    | 从标准输入读取整行数据，不限制输入长度，无论缓冲区大小如何都会导致溢出（已被 C11 标准移除）。 | fgets（需手动处理      |

下面关于WWW论述不正确的是( )。

- ☒ A WWW是因特网提供的一种服务;
- ☐ B WWW是全球最大的分布式数据资源系统;
- ☐ C WWW是全球最大的互联网络;
- ☐ D WWW提供服务的方式是基于C/S架构;

因特网是全球最大的互联网络，而 WWW（万维网）是因特网提供的一种服务

某校园网的地址是202.100.192.0/18,要把该网络分成30个子网,则子网掩码应该是( )。

- ☒ A 255.255.254.0
- ☐ B 255.255.224.0
- ☐ C 255.255.200.0
- ☐ D 255.255.255.0

答案是 A。

1. 首先明确原网络地址是 202.100.192.0/18，即前 18 位是网络位。
2. 要划分成 30 个子网，因为  $\lceil 2^5 = 32 \rceil \geq 30$ ，所以需要从主机位借 5 位来划分子网，此时网络位变为  $\lceil 18 + 5 = 23 \rceil$  位。
3. 子网掩码中，网络位用 1 表示，主机位用 0 表示。/18 对应的子网掩码是 255.255.192.0，借 5 位后，子网掩码的二进制为 11111111.11111111.11111000.00000000，转换为十进制就是 255.255.254.0，所以选 A。

FTP客户端与服务器建立连接后,用PORT命令向服务器通告本地IP地址和端口号:PORT 192,168,0,10,13,128,则客户端开放的端口号为( )。

- ☐ A 1664
- ☒ B 3456
- ☐ C 141
- ☐ D 32781

答案为 B。

解析: FTP 的 PORT 命令格式中, 后两位数字用于计算端口号, 计算方式是  $13 \times 256 + 128 = 3456$ , 所以客户端开放的端口号是 3456, 选 B。

TFTP协议传输的数据长度是固定的,为( )

- ☐ A 1024字节
- ☒ B 512字节
- ☐ C 1500字节
- ☐ D 65535字节

复习计算机网络

为了提高传输效率,TCP通常采用( )。

- ☐ A 端口机制
- ☐ B 三次握手法
- ☐ C 自动重发机制
- ☒ D 窗口控制机制

移动IP的主要目标是? ( )

- ☒ A 动态分配IP地址
- ☐ B 加密数据传输
- ☐ C 提高网络传输速度
- ☒ D 允许设备切换网络时保持IP地址不变

当主机的ARP缓存中无目标IP的映射时,会触发?( )

- ☐ (A) 向DNS服务器查询
- ☐ (B) 丢弃数据包
- ☒ (C) 发送ICMP重定向报文
- ☐ (D) 广播ARP请求报文

答案是 D。

解析：当主机 ARP 缓存无目标 IP 映射时，会广播 ARP 请求报文，询问目标 IP 对应的 MAC 地址，A 是域名解析、B 丢弃不合理、C 重定向不是此时动作，所以选 D。

有四个子网：196.199.48.0/24,196.199.49.0/24,196.199.50.0/24, 196.199.51.0/24, 将它们聚合为( )。

- ☒ (A) 196.199.48.0/22
- ☐ (B) 196.199.51.0/22
- ☐ (C) 196.199.51.0/24
- ☐ (D) 196.199.48.0/24

答案为 A。

解析：将四个子网 196.199.48.0/24、196.199.49.0/24、196.199.50.0/24、196.199.51.0/24 聚合，先看网络位，前 22 位相同（48 的二进制是 00110000，49 是 00110001，50 是 00110010，51 是 00110011，前 22 位为 196.199.001100 00），所以聚合后是 196.199.48.0/22，选 A。

移动IP中,负责为移动节点转发数据包到其当前位置的实体是?( )

- ☐ A DNS服务器
- ☐ B 默认网关
- ☐ C 外地代理(Foreign Agent)
- ☒ D 家乡代理(Home Agent)

下面对DHCP协议描述不正确的是( )

- ☒ A DHCP客户机可以通过DHCP协议更新其DNS入口。
- ☐ B DHCP允许新入网的主机动态的分配网络地址和配置;
- ☐ C DHCP是动态主机配置协议;
- ☒ D DHCP建立在BOOTP的基础上,但保持一些反向相容性;

答案不是 A，正确答案是 D。

解析：

- 选项 A：DHCP 客户机可以通过 DHCP 协议更新其 DNS 入口，该描述正确。
- 选项 B：DHCP 主要功能就是为新入网主机动态分配网络地址（如 IP 地址等）和配置，描述正确。
- 选项 C：DHCP 全称就是动态主机配置协议（Dynamic Host Configuration Protocol），描述正确。
- 选项 D：DHCP 建立在 BOOTP 基础上，保持的是向前兼容性（能兼容处理 BOOTP 相关操作等），而非反向兼容性，该描述错误，所以选 D。

ARP攻击防御的三个控制点不包括( )。

- ☐ A 用户主机
- ☒ B 防火墙
- ☐ C 交换机
- ☐ D 网关

下面关于POP3协议和SMTP协议功能论述正确的是( )。

- ☒ A 本地代理到远程邮件服务器用SMTP,邮件服务器到接收代理使用POP3;
- ☐ B 本地代理到远程邮件服务器用POP3,邮件服务器到接收代理使用SMTP;
- ☐ C 用户代理和本地邮件服务器通信使用POP3,邮件服务器之间通信使用SMTP;
- ☐ D 只有从远程邮件服务器读取邮件时,才使用POP3,其它的都使用SMTP;

这道题目是关于电子邮件协议的功能和使用场景的。选项A是正确的，解释如下：

- **SMTP（简单邮件传输协议）**：用于发送邮件，从本地代理到远程邮件服务器使用SMTP。
- **POP3（邮局协议第3版）**：用于接收邮件，从邮件服务器到接收代理使用POP3。

选项A正确地描述了这两种协议的使用场景：

- 本地代理到远程邮件服务器使用SMTP。
- 邮件服务器到接收代理使用POP3。

其他选项的描述有误：

- 选项B将SMTP和POP3的使用场景颠倒了。
- 选项C描述了用户代理和本地邮件服务器之间的通信使用POP3，这是不准确的，因为用户代理和本地邮件服务器之间的通信通常使用IMAP或POP3，但邮件服务器之间的通信使用SMTP。
- 选项D的描述过于绝对，不完全准确。

因此，正确答案是A。

网段内的其他主机发给该用户的所有数据都被重定向到错误的MAC地址,同网段内的用户无法正常互访,这种是( )攻击造成的。

- ☒ A ARP泛洪
- ☐ B 欺骗终端用户
- ☐ C 仿冒网关
- ☐ D 欺骗网关

下面关于ICMP协议的论述正确的是( )。

- ☒ A ICMP协议由TCP协议承载;
- ☐ B ICMP协议由应用层协议承载;
- ☐ C ICMP协议由IP协议承载;
- ☐ D ICMP协议由UDP协议承载;

以下十六进制标志位0x8180中,QR位的值表示什么?( )

- ☐ A 递归请求
- ☐ B 查询报文
- ☒ C 响应报文
- ☐ D 截断报文

1. 先解析十六进制 `0x8180` 的二进制

- 十六进制转二进制: `0x8180` 换算成二进制是 `1000 0001 1000 0000` 。

- DNS 标志位里, QR 位是最高位(第 16 位, 从 0 开始数是第 15 位), 这里最高位是 `1` 。

2. 明确 QR 位的定义规则

DNS 协议中, QR 位(Query/Response)用于区分报文是“查询”还是“响应”:

- `QR = 0` : 表示这是一条 查询报文(Query), 即客户端向 DNS 服务器发起的查询请求(如查询域名对应的 IP)。

- `QR = 1` : 表示这是一条 **\*\*响应报文\*\*** (Response), 即 DNS 服务器向客户端返回的查询结果。

### 3. 逐一分析选项

- A 选项 (递归请求) :

递归请求由 “RD 位 (Recursion Desired)” 控制, 和 QR 位无关。若 RD = 1 表示客户端请求递归查询, RD = 0 表示迭代查询。所以 A 错误。

- B 选项 (查询报文) :

查询报文的 QR 位是 `0`, 但本题中 QR 位是 `1`, 显然不匹配。所以 B 错误。

- C 选项 (响应报文) :

因为 QR = 1, 完全符合 DNS 响应报文的定义。所以 C 正确。

- D 选项 (截断报文) :

截断报文由 “TC 位 (Truncated)” 控制, TC = 1 表示报文因长度超过限制被截断, 和 QR 位功能无关。所以 D 错误。

综上, 根据 QR 位定义和标志位解析, 答案选 C (响应报文)。核心逻辑就是记住 DNS 标志位里 QR 位 “0 查 1 响” 的规则, 结合十六进制转二进制找到最高位判断。



网络中常见端口号与对应协议可按功能分类梳理，方便理解记忆：

一、基础网络通信类

| 端口号   | 协议        | 功能描述                                          |
|-------|-----------|-----------------------------------------------|
| 20    | FTP（数据端口） | 文件传输协议的数据传输通道                                 |
| 21    | FTP（控制端口） | 文件传输协议的命令控制通道，建立连接、管理传输                       |
| 22    | SSH       | 安全远程登录、文件传输，替代 Telnet（加密更安全）                  |
| 23    | Telnet    | 远程登录（明文传输，安全性低，渐被 SSH 取代）                     |
| 25    | SMTP      | 简单邮件传输协议，用于邮件发送（服务器间投递、客户端发信到服务器）             |
| 53    | DNS       | 域名解析协议，将域名转换为 IP 地址                           |
| 67/68 | DHCP      | 动态主机配置协议，67 为服务器端端口，68 为客户端端口，用于自动分配 IP 等网络参数 |
| 69    | TFTP      | 简单文件传输协议，轻量无认证，常用于小文件、网络设备初始化                 |

## 二、邮件收发类

| 端口号 | 协议        | 功能描述                                     |
|-----|-----------|------------------------------------------|
| 110 | POP3      | 邮局协议版本 3，用于客户端从邮件服务器拉取邮件（默认不加密，会留存服务器备份） |
| 143 | IMAP      | 互联网邮件访问协议，可在线管理邮件（如文件夹操作），支持部分或全部下载邮件    |
| 465 | SMTPS     | 基于 SSL 加密的 SMTP，增强邮件发送安全性                |
| 587 | SMTP 提交端口 | 现代邮件提交常用，需身份验证，配合 TLS 加密                 |
| 993 | IMAPS     | 基于 SSL 加密的 IMAP，加密通信防窃取                  |
| 995 | POP3S     | 基于 SSL 加密的 POP3，加密拉取邮件过程                 |

## 三、网页与安全通信类

| 端口号 | 协议    | 功能描述                                     |
|-----|-------|------------------------------------------|
| 80  | HTTP  | 超文本传输协议，明文传输网页内容，浏览器默认访问端口               |
| 443 | HTTPS | 基于 SSL/TLS 加密的 HTTP，保障网页数据传输安全（如支付、登录场景） |

| 端口号  | 协议         | 功能描述                            |
|------|------------|---------------------------------|
| 8080 | HTTP 备用端口  | Web 服务备用，开发环境、代理服务器常用           |
| 8443 | HTTPS 备用端口 | HTTPS 备用，类似 8080，用于加密服务备用或自定义场景 |
|      |            |                                 |

若DNS响应报文中Answer RRs字段为0x0003,表示: ( )

- ☐ A 请求失败,错误码为3
- ☒ B 包含3条回答记录
- ☐ C 包含3个额外记录
- ☐ D 授权服务器数量为3

答案选 B。

解析：DNS 响应报文中，Answer RRs 字段表示回答资源记录的数量，0x0003 即十进制的 3，所以表示包含 3 条回答记录。

数据源认证服务需要使用的安全机制包括( )。

- ☒ A 访问控制
- ☒ B 认证交换
- ☒ C 数字签名
- ☒ D 加密

根据题目“数据源认证服务需要使用的安全机制包括()”，结合选项和相关知识，正确答案是：

C. 数字签名 和 D. 加密

解析：

1. 数字签名 (C)：

- 数字签名是数据源认证服务中非常重要的安全机制。它通过使用私钥对数据进行签名，然后用公钥验证签名，确保数据的完整性和来源的可信性。数字签名可以防止数据在传输过程中被篡改，并确认数据确实来自声称的发送者。

2. 加密 (D)：

- 加密机制用于保护数据的机密性，确保数据在传输过程中不被未授权者解读。在数据源认证中，加密可以防止数据在传输过程中被窃听或篡改，从而增强数据的可信度。

重放攻击破坏了信息的( )。

- ☐ A 机密性
- ☐ B 可控性
- ☐ C 可用性
- ☒ D 可鉴别性

不可抵赖服务需要使用的安全机制包括( )。

- ☐ A 加密
- ☒ B 认证交换
- ☒ C 数字签名
- ☒ D 公证

答案为 BCD 。

解析：不可抵赖服务需确保行为可追溯、不可否认，认证交换确认身份，数字签名用于防否认，公证可提供第三方证明；加密主要保障机密性，不是不可抵赖的核心机制，所以选 BCD 。

下列攻击方式中,最能代表网络战攻击水平的是( )。

- ☐ A 网络监听
- ☒ B APT 攻击
- ☐ C 缓冲区溢出攻击
- ☐ D 口令破解

元安全属性“可鉴别性”主要包括以下安全属性( )。

- ☒ A 真实性
- ☒ B 完整性
- ☐ C 稳定性
- ☒ D 不可抵赖性

- 1、简述安全机制与安全服务的区别与联系。
- 2、简述网络攻击过程的六个阶段及其主要任务。
- 3、网络或信息系统的安全属性有哪些？简要解释每一个安全属性的含义。
- 4、假定你是本单位的安全主管，为了提高本单位的网络安全，在制定单位的安全保障方案时，有哪些措施（包括技术和非技术的）？
- 5、在 P2DR 安全模型中，假设攻击时间是 100 个单位时间，检测时间是 40 个单位时间，响应时间要满足什么条件，被防护的系统才是安全的？并给出计算过程。

以下是对这 5 个问题的解答：

## 1、安全机制与安全服务的区别与联系

- 区别：

- 安全服务：是面向用户的“结果导向”能力，解决“要保护什么”，比如提供数据机密性（让数据仅授权者能看）、完整性（数据不被篡改）等，是用户能感知到的防护效果。

- 安全机制：是实现服务的“技术手段”，解决“怎么保护”，像加密、数字签名、访问控制这些具体技术，是底层支撑逻辑。

- 联系：安全服务依赖安全机制实现。例如，“数据机密性”服务靠“加密机制”达成；“抗抵赖”服务靠“数字签名机制”支撑，一种服务可由多种机制配合，一种机制也能为多个服务提供支持。

## 2、网络攻击过程的六个阶段及其主要任务

1. 侦察（信息收集）：攻击者被动/主动收集目标信息，比如查域名 Whois、扫描端口开放情况、搜员工邮箱（社工信息），为后续攻击找入口。

2. 扫描（脆弱性探测）：用工具扫描目标网络/系统，找开放端口、服务版本、漏洞（如用 Nmap 扫端口，用漏洞扫描器查 SQL 注入、弱密码）。

3. foothold（获取访问权）：利用找到的漏洞（如 SQL 注入拿数据库权限、利用系统漏洞提权），突破防线进入目标系统。

4. 维持访问（持久化控制）：留后门（如创建隐藏账户、植入远控木马），确保被发现后还能重新连入，长期控制目标。
5. 行动（达成攻击目的）：根据意图搞破坏/窃取，比如删数据、盗账号密码、传敏感文件到自己服务器。
6. 清理痕迹（隐藏证据）：删日志（系统日志、操作记录）、改时间戳，躲避管理员/审计发现。

### 3、网络或信息系统的安全属性及含义

- 机密性：数据/信息仅授权者能访问、读取，防未经授权泄露（如企业客户资料、军事加密通信）。
- 完整性：数据在传输/存储中不被篡改、破坏，确保真实有效（如金融交易数据、系统配置文件）。
- 可用性：授权用户需要时，系统/服务能正常用，不被拒绝服务攻击（DDoS）等打断（如电商平台高峰下单、医院急救系统）。
- 不可抵赖性：操作行为可追溯、不可否认，靠数字签名、日志等实现（如电子合同签署、邮件发送者身份）。
- 可控性：管理员能管控系统，包括访问权限、操作审计、行为限制（如企业内网限制违规软件安装）。

### 4、单位网络安全保障方案的技术 + 非技术措施

#### 技术措施

- 边界防护：部署防火墙（ACL 策略控流量）、入侵检测/防御系统（IDS/IPS）拦攻击。
- 身份与访问控制：用多因素认证（密码 + 验证码/指纹），按最小权限原则分配账号权限。
- 数据保护：敏感数据加密（数据库加密、传输 TLS 加密），定期备份（异地/离线备份防勒索）。
- 漏洞管理：定期扫漏洞（用 Nessus 等工具），及时打补丁（如操作系统、业务系统漏洞）。
- 监控审计：搭日志审计系统（如 ELK），实时监控网络流量、操作行为，留痕溯源。

## 非技术措施

- 制度流程：定网络安全制度（如密码更换周期、外来设备接入审批），出应急响应预案（ransomware、数据泄露时咋处理）。
- 人员培训：定期搞安全意识培训（防钓鱼邮件、社工攻击），让员工懂基本安全操作（不随便点陌生链接）。
- 合规与管理：遵循行业安全标准（等保、ISO 27001），签第三方合作安全协议（外包商、云服务商）。

## 5、P2DR 模型中响应时间计算

P2DR 模型核心逻辑：防护时间 > 检测时间 + 响应时间，系统才安全（攻击时间突破防护前，要完成检测 + 响应拦截）。



已知：攻击时间（ $P_t$ ）= 100，检测时间（ $D_t$ ）= 40

设响应时间为  $R_t$ ，需满足：

$$P_t > D_t + R_t$$

代入得：

$$100 > 40 + R_t$$

解得：

$$R_t < 60$$

即响应时间要 小于 60 个单位时间，系统才安全。（只要检测 + 响应的总耗时比攻击突破防护的时间短，就能拦截攻击）

Web 浏览器和服务器使用 HTTPS 协议进行通信,可确保通信的( )。

- ☒ A 完整性
- ☐ B 可靠性
- ☒ C 服务器的真实性
- ☒ D 机密性

答案为 ACD。

解析：HTTPS 基于 SSL/TLS，加密保证机密性，哈希等保证完整性，数字证书保证服务器真实性；可靠性主要由 TCP 保障，并非 HTTPS 核心，所以选 ACD。

下列攻击中,针对 OSPF 协议的攻击包括( )。

- ☐ A 篡改 IP 包中的协议字段
- ☒ B LSA 报文重放攻击
- ☒ C 最大年龄(Max Age attack)攻击
- ☒ D 最大序列号攻击

以下哪种网络拓扑结构对单点故障最敏感?

- ☐ A 环型拓扑
- ☒ B 星型拓扑
- ☐ C 网状拓扑
- ☐ D 总线型拓扑

答案为 B。

解析：星型拓扑以中心节点为核心，所有节点连到中心，中心节点故障会致整个网络瘫痪，对单点故障最敏感；环形拓扑一个节点故障可能影响环但可通过冗余改善，网状拓扑有多条路径，总线型拓扑总线故障影响大但单点（非总线）故障影响小，所以选 B。

以下哪些协议易遭受拒绝服务()攻击?()

- ☒ A TCP(SYN Flood)
- ☒ B ICMP(Ping Flood)
- ☒ C BGP(路由表溢出)
- ☒ D DHCP(DHCP Starvation)

很多单位的安全管理员会在防火墙的设置中禁用因特网控制管理协议ICMP,主要原因是攻击者常常使用 ICMP 进行( )。

- ☒ A 主机扫描
- ☒ B 拒绝服务攻击
- ☒ C 隐蔽通信
- ☐ D 会话劫持

网络层典型攻击手段包括?

- ☐ A SYN Flood
- ☐ B DNS放大攻击
- ☒ C ARP缓存投毒
- ☒ D IP欺骗

## 网络协议与攻防技术

2225060672 周朝川

1. 从网络协议与攻防技术来看，因特网在体系结构上有什么不足之处？

① 协议层安全缺陷：

TCP/IP协议设计初期未充分考虑安全性。

导致IP协议易被伪造（IP欺骗）。

缺乏认证与数据包溯源机制，ICMP、UDP、TCP三协议存在漏洞。

② 分组交换架构隐患。

基于分组交换的设计使所有用户共享资源，

攻击数据包在判定恶意前仍被转发，

且路由分散决策导致流量无序，易受中间点劫持。

③ 认证与可追踪性缺失。

终端接入无需严格认证，攻击者可伪造数据包

并隐藏来源，而路由器缺乏追踪功能，例如ARP协议

易受投毒攻击。

2. TCP协议的哪些字段/特性可被攻击者利用？

① SYN标志位：通过发送大量伪造的SYN包，  
耗尽服务器的半连接队列资源，  
导致SYN泛洪攻击。

② 序列号ISN：利用初始序列号的随机性不足或可预测，  
实施会话劫持或构造隐蔽通道  
传输数据。

③ RST标志位：伪造RST包强制终止合法连接，  
实现TCP重置攻击。

④ 窗口通告机制：伪造极小的窗口值干扰流量控制，  
降低通信效率或耗尽资源。

⑤ URG指针与紧急数据：滥用紧急指针触发目标系统异常  
处理。

⑥ ACK机制：中间人攻击中伪造ACK包劫持会话或注入恶意数据。

⑦ 源/目标端口及IP字段：伪造相同源和目标地址（如LAND攻击）  
使目标陷入死循环。



### 3. 列举OSI七层模型中每层的典型安全威胁

- 物理层
  - 拒绝物服务攻击(如DDoS): 物理干扰破坏比特流传输
  - 直接破坏硬件措施
  - 物理嗅探(如电缆窃听)截取数据
- 数据链路层
  - ARP欺骗: 伪造MAC地址劫持通信
  - MAC泛洪: 淹没交换机转发表导致网络瘫痪
  - 生成树攻击: 操纵生成树协议引发环路
- 网络层
  - DDoS攻击: 通过大量耗尽网络资源的请求, 完成拒绝服务
  - IP欺骗
  - 路由攻击
- 传输层协议
  - SYN泛洪: 耗尽连接资源导致服务中断
  - Smurf攻击: 利用ICMP协议放大攻击流量
- 会话层
  - 会话劫持: 窃取会话标识符冒充合法用户
  - 中间人攻击: 拦截并篡改会话数据
- 表示层
  - SSL劫持: 破坏加密协议窃取敏感信息
- 应用层
  - 病毒/蠕虫/木马: 通过恶意代码破坏应用服务
  - 钓鱼攻击: 伪造界面诱导点击
  - XSS/SQL Injection: 利用Vuln Vulnerability执行恶意操作

### 4. ARP协议哪些字段/特性可被攻击者利用?

- ① 无认证机制: 默认信任所有节点, 未对报文进行身份验证, 攻击者可伪造ARP响应报文(冒充网关/主机)篡改目标设备ARP表项
- ② 广播特性: 攻击者可监听网络并发送虚假ARP响应, 将通信流量劫持至自身
- ③ 操作字段: 攻击者可构造恶意ARP报文, 利用Operation Code(如ARP应答)伪装成合法设备, 实施中间人攻击或ARP欺骗
- ④ 代理ARP漏洞: 攻击者利用跨接口的ARP表项泄漏, 若设备启用代理ARP且存在软件缺陷, 流量将导向错误网络

2225060672

周梓涵

简述可能导致软件安全漏洞出现的原因。

分析 HTTP/1.1 的以下请求，指出潜在的安全风险：

```
GET /login.php?username=admin&password=123456 HTTP/1.1
```

```
Host: example.com
```

5. 简述可能导致软件安全漏洞出现的原因。
- ① 编码不当：  
不安全的编码习惯（如未验证用户输入导致SQL注入、缓冲区溢出...）以及使用低级语言时直接操作内存引发的漏洞。
  - ② 配置错误：云服务数据库或网络设置的错误配置可能暴露未授权访问入口。
  - ③ 未及时更新补丁：未修复已知漏洞（如log4shell）使系统易受攻击。
  - ④ 人为因素：信息泄露、密码管理不当（如弱密码、密码重用）。
6. 分析 HTTP/1.1 的以下请求，指出潜在安全风险：
- ```
GET /login.php?
username=admin&password=123456.
HTTP/1.1
Host:example.com
```
- ① 使用GET方法传输敏感信息，导致信息被记录在日志和浏览历史中。
  - ② 密码以明文形式传输，使用HTTP（不带TLS/SSL）易被中间人攻击窃取。
  - ③ 密码强度太弱易被暴力破解。

#### 第6题

##### 风险：

明文传输敏感信息（密码）。

可能遭受 SQL 注入（若服务端未过滤输入）。

##### 改进：

使用 HTTPS 加密传输。

改用 POST 方法提交表单。

DNS协议的主要安全风险是？

- ☐ A 协议过于复杂
- ☐ B 数据加密不足
- ☒ C 缓存投毒(DNS Cache Poisoning)
- ☐ D 带宽耗尽

下列交换方式中,最容易被攻击的是( )。

- ☒ A 报文交换
- ☐ B 电路交换
- ☒ C 分组交换
- ☐ D 专线

答案为 C。

解析:分组交换将数据拆分成分组独立传输,分组可能被截获、篡改、伪造,易受攻击;报文交换虽也有风险,但分组交换因分组多、路径灵活,攻击面更广;电路交换有独占链路,专线是专用连接,相对更安全,所以选 C。

下面有关 ARP 协议的描述中,( )是错误的。

- ☐ A ARP 协议可被用来进行拒绝服务攻击
- ☐ B 一般情况下,当主机收到 ARP 请求或响应时,需要刷新其 ARP 缓存
- ☒ C ARP 欺骗可在本地网络以外成功使用
- ☐ D ARP 欺骗只能被用于本地网络

答案为 C。

解析:ARP 协议基于局域网广播工作,ARP 欺骗依赖本地网络广播域,无法在本地网络以外(跨网段)成功实施,C 错误;A ARP 可通过大量伪造报文实施拒绝服务攻击,B 主机收到 ARP 请求/响应会刷新缓存保证正确性,D 说明 ARP 欺骗的本地局限性,所以选 C。

以下哪项属于被动侦察?()

- ☐ A 暴力破解密码
- ☒ B 通过Shodan搜索暴露的设备
- ☐ C 使用Nmap扫描端口
- ☐ D 发送ICMP请求探测主机

如果要查询 yahoo.com 是在哪个域名注册机构注册的,最合适的 Whois 数据库是 ( )。

- ☒ A InterNIC 的 Whois 数据库
- ☐ B CNNIC 的 Whois 数据库
- ☐ C RIPE 的 Whois 数据库
- ☐ D IANA 的 Whois 数据库

网络扫描一般不会使用( )进行。

- ☐ A TCP协议
- ☐ B IP协议
- ☒ C DNS协议
- ☐ D ICMP协议

为了防止网络扫描行为被网络安全系统发现,不应当采用( )策略。

- ☒ A 连续端口快速扫描
- ☐ B 伪造源地址
- ☐ C 分布式扫描
- ☐ D 随机端口扫描

端口扫描的主要功能是( )。

- ☐ A 探测主机是否开机
- ☒ B 探测目标主机上开放了哪些网络服务
- ☐ C 识别操作系统的类型
- ☐ D 判断目标主机上是否存在某个已公开的漏洞

以下哪些是Nmap的常用功能?()

- ☒ A 防火墙规则探测(Firewall Evasion)
- ☒ B 服务版本探测(Service Version Detection)
- ☐ C 漏洞自动利用(Exploit Execution)
- ☒ D 操作系统指纹识别(OS Detection)

识别目标主机操作系统类型的扫描技术称为:()

- ☐ A 漏洞扫描
- ☒ B 端口扫描
- ☐ C 服务扫描
- ☒ D OS指纹识别

网络扫描包括()。

- ☒ A 操作系统识别
- ☒ B 端口扫描
- ☒ C 主机扫描
- ☒ D 漏洞扫描

Nmap工具可以执行哪些类型的扫描?()

- ☒ A SYN扫描(半开放扫描)
- ☐ B ARP欺骗扫描
- ☒ C UDP扫描
- ☒ D Xmas扫描(FIN/URG/PSH标志位组合)



1. 简述 TCP SYN 扫描 (半开放扫描) 的工作原理及其优缺点。

原理: 扫描器向目标端口发送 SYN 包, 若收到 SYN-ACK 响应,

说明端口开放, 再发送 RST 包中断连接;

若收到 RST 响应, 说明端口关闭。

优点: 隐蔽性高, 不易被日志记录, 无需完成连接。

缺点: 需构造和处理底层数据包, 实现复杂;

部分防火墙可过滤 SYN 包, 影响扫描效果。

2. ICMP 协议在网络扫描中的利用。

Ping 扫描 (主机发现): 发送 ICMP Echo 请求, 若收到 Echo 回复, 判断主机存活。

Traceroute (路由跟踪): 发送 TTL 递减的 UDP/ICMP 包, 利用 ICMP 超时消息记录路由节点。

ICMP 端口不可达扫描: 结合其他协议, 通过 ICMP 端口不可达消息判断端口状态。

3. 操作系统识别的目的与方法。

目的: 确定目标系统类型、版本, 以便于针对性实施安全策略。

(如补丁更新、防护规则设置或攻击(如利用特定漏洞))。

方法: 主动识别: 发送特定 TCP/UDP/ICMP 包, 分析响应特征。

被动识别: 监听网络流量, 分析操作系统在通信中的特征。

4. 漏洞扫描对网络安全的意义。

发现弱点: 检测系统、应用、网络中的漏洞。

风险评估: 量化安全风险, 为优先级处理提供依据。

合规性: 满足安全标准对漏洞管理要求。

5. 端口扫描防护方案。

技术措施: 防火墙过滤 - IPS/IDS - 流量整形 - 关闭不必要服务。

管理措施: 定期更新 - 员工培训 - 安全审计 - 制定应急预案。

反射型拒绝服务攻击在选择用作攻击流量的网络协议时, 通常依据以下原则 ( )。

- ☐ A 协议具有有连接特性
- ☒ B 互联网上有很多可探测到的支持该协议的服务器
- ☒ C 协议具有无连接特性
- ☒ D 部分协议的请求报文大小远小于响应报文的大小

下列协议中, 可用作反射型拒绝服务攻击的包括是 ( )。

- ☒ A NTP
- ☒ B SSDP
- ☐ C UDP
- ☐ D TCP

网络协议与攻防  
攻击者在选择用做DDoS攻击流量协议时，主要考虑的因素？  
易被利用的协议：

- 传输层协议：  
TCP协议、QUIC
- 网络层协议：  
IP协议、ICMP协议
- 应用层协议：HTTP协议

攻击者选协议的因素：

协议漏洞与设计缺陷  
利用协议固有弱点如TCP三次握手缺陷，UDP无连接性  
支持反射放大机制：DNS、NTP协议因响应包大于请求包，  
可显著提升攻击效率

攻击效果最大化  
带宽消耗：优先选择放大因子高的协议  
资源耗尽：针对服务器处理能力，应用层资源  
成本效率

隐蔽性与追踪难度

20250606T2  
周景山

## 2. 僵尸网络有几种类型并分析每种类型的优缺点。

集中式僵尸网络(C/S结构)

子类型：IRC协议僵尸网络，HTTP协议僵尸网络  
特点：依赖中心服务器分发指令，僵尸主机与中心节点单向通信  
优点：控制高效，维护简单  
缺点：单点故障风险，易被检测

点对点僵尸网络(P2P)

子类型：集中式P2P，非结构化P2P，结构化P2P  
特点：节点间对等连接，无中心服务器，  
指令通过分布式网络传播  
优点：高抗毁性，  
隐蔽性强  
缺点：路由效率低

混合型：

优点：灵活，兼具集中式的高效与P2P的抗毁性  
缺点：架构设计与维护难度大



3. 为了应对攻击者利用分片来穿透防火墙, 防火墙在检测时进行数据包重组, 仅当重组后数据包符合通信规则时, 数据包片段才可放行。攻击者如何利用防火墙这一处理机制对防火墙攻击?

可以精心构造分片参数或恶意分片组合实施多种攻击:

#### 一、微小分片攻击:

① 拆分TCP头部: 将TCP头部信息, 拆分至第二个分片中, 使防火墙仅检查第一个分片的IP头信息, 而放行后续分片。

② 强制分片偏移: 将分片偏移量改为1, 迫使TCP头部进入第二个分片。由于防火墙可能仅检查第一个分片的SYN标志, 后续分片可直接穿透。

#### 二、重叠分片攻击:

1. 偏移覆盖: 发送多个分片偏移重叠的数据包, 导致目标系统重组时发生内存错误/逻辑混乱, 引发崩溃或重启。

#### 2. Bank攻击变种:

通过偏移覆盖构造合法TCP/UDP头部。

#### 三、其他

1. 死亡之Ping: 发送超65535字节的IP分片, 目标重组时触发缓冲区溢出, 导致系统崩溃。

2. 协议栈漏洞利用: 针对特定操作系统分片重组漏洞实施定向攻击。

2225060672 周幸宇训

4. 直接风暴型拒绝DOS与反射式风暴型DOS的区别是什么? 有哪些网络协议被攻击者用来进行风暴型拒绝服务攻击? 如果你是一个攻击者, 在选择风暴型DOS攻击的网络协议时主要考虑哪些因素。

攻击路径: { 直接~: 由攻击者控制的肉鸡直接向目标发送海量数据  
反射~: 利用第三方服务器作为反射源。攻击者构造目标IP向这些服务器发送请求。

资源消耗方式: { 直接~: 依赖僵尸网络规模  
反射~: 利用协议特性放大流量

隐蔽性: { 直接~: 易被防御且溯源  
反射~: 含该服务器, 隐藏IP

利用协议: { 直接: ICMP, TCP, UDP, HTTP  
反射: NTP, DNS, SSDP

攻击者选择协议关键因素: 协议普及度, 放大倍数, 可探测性, 隐蔽性

以下哪项是DDoS攻击的间接影响?()

- ☐ A 数据库被加密勒索
- ☒ B 内部网络被监听
- ☐ C 服务器数据被删除
- ☒ D 合法用户无法访问服务

僵尸网络在DDoS攻击中的作用是?()

- ☐ A 加密受害者数据
- ☐ B 修复系统漏洞
- ☐ C 窃取用户凭证
- ☒ D 提供分布式攻击流量

什么是“零日DDoS攻击”?()

- ☐ A 仅在午夜发起的攻击
- ☒ B 利用未知漏洞发起的攻击
- ☐ C 仅针对移动设备的攻击
- ☐ D 无需僵尸网络的攻击

以下哪项是DDoS攻击的合法用途?()

- ☐ A 匿名化网络流量
- ☐ B 窃取数据
- ☐ C 破坏竞争对手服务
- ☒ D 压力测试(需授权)

下列协议中,可用作拒绝服务攻击的有( )。

- ☒ A HTTP
- ☒ B UDP
- ☒ C ICMP
- ☒ D TCP

进程隐藏技术包括()

- ☒ A 将自身进程从活动进程链表上摘除
- ☒ B API Hook
- ☐ C DLL注入
- ☒ D 修改显示进程的命令

杀毒软件为了防止恶意代码侵入计算机,通常要监控Windows系统中的( )。

- ☐ A Office 文档
- ☒ B 系统文件
- ☒ C 注册表
- ☐ D 用户的文本文件

单项选择题 1. 关闭网络端口( )可阻止勒索病毒 WannaCry 传播。

- ☐ A 23
- ☐ B 115
- ☒ C 445
- ☐ D 25



1. 远程控制型木马与远程控制软件的区别  
远程控制软件是合法工具, 经用户授权后用于正常管理与技术支持  
远程控制型木马是恶意程序, 未经授权后便偷偷植入, 用于窃取信息、破坏系统等非法目的
2. 黑客利用远程控制型木马进行网络入侵的几个步骤  
① 目标选择 ② 木马传播 ③ 植入与隐藏  
④ 建立连接 ⑤ 数据窃取/控制 ⑥ 进一步渗透
3. 远程控制型木马采用反向连接技术的优点  
① 突破防火墙限制:  
多数防火墙允许内部设备主动发起连接, 反向连接更易成功  
② 隐藏控制端位置: 控制端无需固定公网IP, 可通过动态域名等方式隐藏存在, 增加追踪难度
4. 木马实现进程隐藏的手段  
① 进程注入 ② DR DLL 注入 ③ 进程列表欺骗
5. 案例分析  
问题1. 木马进入企业网络的途径  
钓鱼邮件附件:  
软件漏洞利用:  
问题2. 预防措施  
员工培训、系统加固、访问控制
6. 案例分析  
问题1. 勒索木马工作流程  
感染传播、文件加密、通信勒索  
问题2. 恢复数据与避免再次感染  
数据恢复: 若有备份则断开网络后从备份恢复  
尝试免费解密工具  
避免感染: 从正规渠道获取软件  
启用防火墙 限制程序网络访问

2225060672  
周影川

常用的木马启动方式包括( )。

- ☒ A 通过 DLL 启动
- ☒ B 开机自启动
- ☒ C Windows 中的计划任务
- ☒ D 文件浏览自动播放

冰河木马是比较典型的一款木马程序,该木马具备以下特征()。

- ☒ A 进程默认名为 Kernel32.exe
- ☐ B 采用了进程注入技术
- ☒ C 在系统目录下释放木马程序
- ☒ D 默认监听 7626端口

病毒扫描软件由( )组成

- ☐ A 仅由利用特征库进行扫描的扫描程序;
- ☐ B 仅由病毒特征库;
- ☒ C 特征库和扫描程序
- ☐ D 以上都不对

攻击者通过发送大量包含常见口令的请求尝试登录系统,这种攻击属于?( )

- ☐ A 中间人攻击
- ☒ B 字典攻击
- ☐ C 暴力攻击
- ☐ D 会话劫持

下列口令攻击算法中,需要使用用户个人信息的是( )。

- ☒ A PCFG 漫步攻击算法
- ☒ B Targeted-Markov 算法
- ☐ C Markov 漫步攻击算法
- ☐ D 穷举攻击

现有研究表明,人类构建的口令服从( )。

- ☐ A 随机分布
- ☐ B 均匀分布
- ☐ C 正态分布
- ☒ D Zipf 分布



1. 静态口令的安全威胁分析:
  - 弱口令与易破解性
  - 口令复用与撞库风险
  - 传输存储漏洞
  - 社会工程学攻击以及内部人员滥用
2. 在集中式对称密钥分配协议 Needham-Schroeder 中,
  - 什么是通信方 A、B 主密钥? 这些主密钥和会话密钥  $K_s$  有何用途? 主密钥如何进行安全分配?
  - 会话密钥如何进行安全分配?
- ① 主密钥: 通信方 A、B 分别与密钥分配中心 KDC 共享的长期对称密钥, 用于信任锚点与会话密钥请求的安全通道
- ② 会话密钥: KDC 生成的临时对称密钥, 供 A、B 单次会话使用
- ③ 主密钥安全分配:
  - 物理/离线方式: 通过安全渠道将主密钥预配置给 A、B 和 KDC 确保不被网络监听
  - 信任假设: 主密钥初始分配依赖物理安全/高度信任环境
- ④ 会话密钥安全分配 (协议流程)
  - A 向 KDC 申请  $K_s$
  - KDC 生成并分发  $K_s$
  - A、B 验证  $K_s$
3. 设计一个攻破某核心网账户密码的方案
  - 弱口令暴力破解: 使用工具, 针对邮箱登录接口, 构造用户名, 遍历常见字典
  - 钓鱼攻击: 伪造 163 邮箱登录界面, 通过钓鱼邮件或短信, 诱骗用户进入链接并输入密码
4. 设计需要输入图形识别码的网站注册用户口令破解方案
  - 传统 OCR 攻击 (低效, 易被拦截)
  - 基于机器学习攻击
    - 通过社工、漏洞或合法途径获取验证码样本
    - 通过模型训练, 编写脚本调用模型识别验证码
    - 结合暴力破解工具尝试登录

一次性口令()的主要优势是?()

- ☒ A 防止重放攻击
- ☐ B 支持多因素认证
- ☐ C 降低管理成本
- ☐ D 便于记忆

2014 年12 月25日,12306网站部分用户信息在因特网上疯传,黑客获得这些用户信息的最可能方式是( )。

- ☒ A 撞库
- ☐ B 12306 网站管理员故意泄密
- ☐ C 钓鱼邮件
- ☐ D 洗库

在网络上,为了监听效果最好,监听设备应放在( )。

- ☐ A 网关
- ☐ B 防火墙
- ☒ C 内外主机
- ☐ D 路由器

下列措施中,( )可用于防范中间人网络监听。

- ☐ A 授权
- ☒ B 交换机端口绑定
- ☐ C 认证
- ☒ D 通信加密

为了监听 Wi-Fi 通信,攻击者可采用的方法包括( )。

- ☒ A 破解无线路由器的后台管理员口令
- ☐ B ARP 欺骗
- ☒ C 无线热点钓鱼
- ☐ D DNS 劫持

